



Bounty Hacker

Offensive Security Write-up



Autor: Clara Marcela Grossl

Data: March 19, 2026

Sinopse

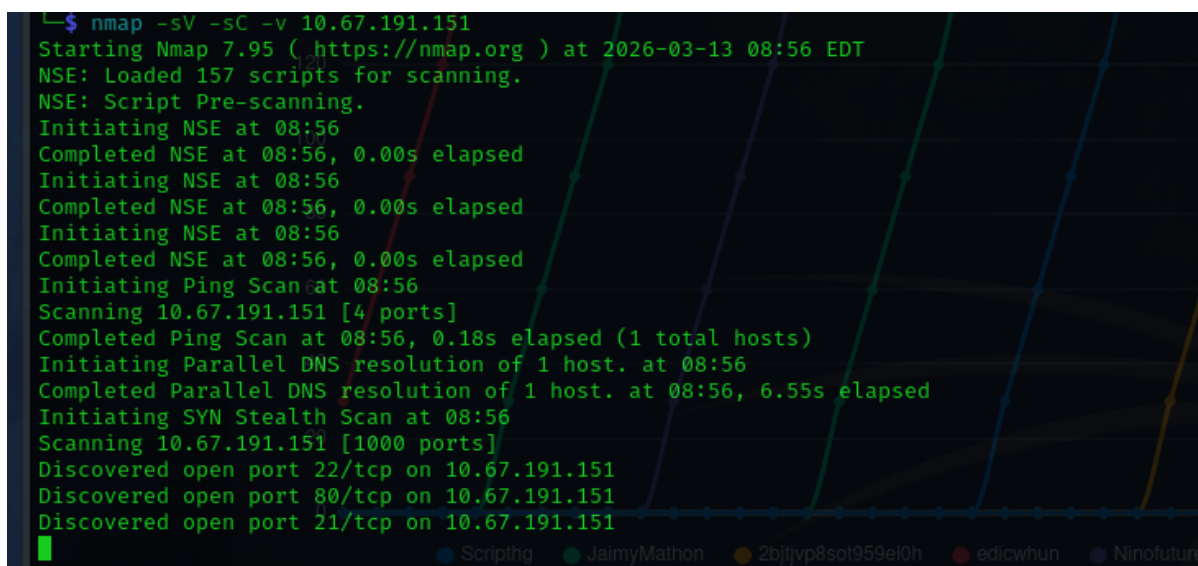
O **Bounty Hacker** é um desafio de CTF que explora falhas comuns em serviços como HTTP, SSH e FTP. O foco inicial é o acesso anônimo ao serviço FTP, que permite a coleta de credenciais para o acesso via SSH. A etapa final consiste na escalção de privilégios para obter o controle total (*root*) do sistema.

1 Enumeração

A fase inicial consistiu na varredura de portas com o nmap para mapear a superfície de ataque.

```
$ nmap -sV -sC -v <IP_DA_MAUQUINA>

# -sV : para obter a versão dos serviços
# -sC : utiliza scripts padrões do Nmap (permite obter chaves ssh e demais
        informações sensíveis)
# -v : aumenta o nível de detalhamento (mostra o que está acontecendo em tempo
        real)
```



```
$ nmap -sV -sC -v 10.67.191.151
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-13 08:56 EDT
NSE: Loaded 157 scripts for scanning.
NSE: Script Pre-scanning.
Initiating NSE at 08:56
Completed NSE at 08:56, 0.00s elapsed
Initiating NSE at 08:56
Completed NSE at 08:56, 0.00s elapsed
Initiating NSE at 08:56
Completed NSE at 08:56, 0.00s elapsed
Initiating Ping Scan at 08:56
Scanning 10.67.191.151 [4 ports]
Completed Ping Scan at 08:56, 0.18s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 08:56
Completed Parallel DNS resolution of 1 host. at 08:56, 6.55s elapsed
Initiating SYN Stealth Scan at 08:56
Scanning 10.67.191.151 [1000 ports]
Discovered open port 22/tcp on 10.67.191.151
Discovered open port 80/tcp on 10.67.191.151
Discovered open port 21/tcp on 10.67.191.151
```

Figure 1 Output do Nmap revelando portas 21, 22 e 80.

A análise do serviço HTTP na porta 80 não revelou vetores de exploração imediatos ou informações sensíveis expostas.

A enumeração do serviço FTP via autenticação anonymous permitiu o acesso ao sistema de arquivos, onde foi identificado um arquivo contendo credenciais em texto plano, fornecendo uma base para tentativas de acesso via SSH.

2 Vulnerabilidade e Exploração

Utilizando a lista de potenciais credenciais adquiridas do serviço FTP, procedeu-se com a validação de autenticação no serviço SSH (porta 22). Para automatizar este processo, empregou-se a ferramenta Hydra, o

que resultou na identificação de um par de credenciais válido, garantindo o acesso inicial ao sistema.

```
## Ataque de força bruta no ssh
$ hydra -l <user> -P locks.txt ssh://<IP>
```

#-l: define o usuário alvo
 #-P: aponta para a wordlist de senhas obtida no FTP

3 Acesso Inicial

Após o acesso inicial, via SSH, obtivemos a flag do usuário.

```

root@kali:~# curl -m 10 -s -o /dev/null -w "%{httpcode}" http://10.10.10.10:22
200
lin@ip-10-67-191-151:~/Desktop$ ls
user.txt
lin@ip-10-67-191-151:~/Desktop$ cat user.txt
The cat has my user name
lin@ip-10-67-191-151:~/Desktop$

```

Figure 2 Flag do usuário.

4 Escalação de Privilégios

Iniciou-se a fase de enumeração visando a identificação de falhas que permitissem a escalação de privilégios. Para tanto, executou-se o comando `sudo -l`, cujo propósito é listar os comandos que o usuário atual possui permissão de executar com privilégios de superusuário (`root`) ou de terceiros.

```
user@<ip>:~$ sudo -l
# Resultado: (root) /bin/tar
```

Conforme demonstrado na saída do comando acima, identificou-se que o usuário possuía permissão excessiva através do `/usr/bin/tar`. Como o `tar` está rodando com privilégios de `root`, qualquer comando definido dentro da flag `--checkpoint-action` também será executado como superusuário. Dessa forma, consultando o site [GTFOBins](#), obtém-se o seguinte comando que permite a escalação para `root` do sistema.

Assim, foi possível capturar a flag final, executando o shell como root.